

VulnPenMCP: Constrained MCP Tool Architecture for Methodologically Consistent Penetration Testing

Vittal Mukunda

Dept. of Industrial Engineering and
Management

R V College of Engineering
Bengaluru, India

vittalmukunda.im24@rvce.edu.in

Ryan Dave Fernandes

Dept. of Computer Science and
Engineering

R V College of Engineering
Bengaluru, India

ryandavef.cs24@rvce.edu.in

Dr. Minal Moharir

Dept. of Computer Science and
Engineering

R V College of Engineering
Bengaluru, India

minalmoharir@rvce.edu.in

Prof. Sebastian Biedermann

Head of bachelor's Program in
Information Security

*Würzburg-Schweinfurt University of
Applied Sciences (THWS)*

sebastian.biedermann@thws.de

Dr. B.M.Sagar

Dept. of Information Science and
Engineering

R V College of Engineering
Bengaluru, India

sagarbm@rvce.edu.in

Abstract— Large language models (LLMs) are increasingly used as autonomous agents for penetration testing, but unrestricted tool invocation can lead to scope violations, improper execution order, and inconsistent vulnerability classification. This paper presents VulnPenMCP, a constrained Model Context Protocol (MCP) server that enforces scope boundaries, penetration testing phase sequencing, and automated MITRE ATT&CK mapping. The system integrates 43 security tools and introduces a protocol-level enforcement mechanism that prevents bypass attempts. Evaluation on a 215-finding corpus shows an F1 score of 0.771, with high recall (0.907), indicating effective ATT&CK mapping. External validation on real-world CVEs demonstrates strong generalization (recall = 0.879). Adversarial testing across 200 attack vectors achieved 100% scope enforcement accuracy. Compared to existing tools such as OWASP ZAP and Burp Suite, VulnPenMCP provides more comprehensive enforcement and significantly improves methodology adherence. These results highlight the importance of protocol-level constraints for reliable and consistent LLM-driven security testing.

Keywords — Model Context Protocol, Penetration Testing, MITRE ATT&CK, Scope Enforcement, LLM Tool-Use, OWASP Top 10, Security Automation, Methodology Adherence, External Validation, DVWA

I. INTRODUCTION

Tools like PentestGPT and VulnBot, which are based on LLMs, have great capability in the area of automated penetration testing, but their drawback lies in the absence of any protocol-based measures. This causes many problems such as violating scope, inaccurate phasing of penetration tests, and inconsistency in vulnerability assessment. However, in actual practice, strictly following scope and methodology is essential.

We present VulnPenMCP, a protocol-constrained MCP server for methodologically consistent LLM-driven penetration testing. We evaluate the system across curated datasets, adversarial inputs, and real-world CVEs, demonstrating improved consistency, robustness, and methodology adherence.

A. Contributions

We make the following contributions:

- 1) A constrained MCP architecture enforcing scope boundaries and PTES phase ordering
- 2) A deterministic ATT&CK mapping approach with strong empirical performance
- 3) Comprehensive evaluation including adversarial testing and real-world validation
- 4) An open-source implementation supporting reproducible security workflows

II. BACKGROUND AND RELATED WORK

This section reviews the foundational technologies and prior work that VulnPenMCP builds upon, covering the Model Context Protocol, established penetration testing standards, the MITRE ATT&CK framework, and existing LLM-driven security tools.

A. Model Context Protocol (MCP)

Model Context Protocol (MCP), released by Anthropic in 2024 [5], is a vendor-neutral protocol layer for LLM interaction with external tooling, implemented via a JSON-RPC 2.0 interface. MCP enables scope enforcement and phase validation at a protocol-level, supporting both stdio and SSE transport mechanisms.

B. OWASP Top 10 and PTES

OWASP Top 10 (2021) [6] presents a list of ten web application risks. We organize our taxonomy tool according to these risk categories. PTES [4] outlines a seven-step penetration testing process with distinct execution phases that we enforce through our lifecycle manager.

C. MITRE ATT&CK Framework

MITRE ATT&CK framework (Enterprise Matrix) [7] provides a rich threat modeling taxonomy. TRAM (Threat

Report ATT&CK Mapper) [8] utilizes natural language processing for automating ATT&CK mapping of threat intelligence reports. Our methodology is more narrowly scoped and uses deterministic keyword matching for structured penetration test tool output analysis with confidence thresholding, which allows us to produce accurate results without relying on machine learning models.

D. LLM-Driven Penetration Testing

GPT-4 was initially applied to penetration testing in PentestGPT [1] and later extended by VulnBot [2] and AutoPenBench [3]. However, these systems lack protocol-level scope enforcement and statistically rigorous adherence to penetration testing phases. TRAM [8], in contrast, provides ATT&CK mappings for threat intelligence reports. A detailed comparison of these approaches is presented in Table 1.

TABLE I. Comparison Against Prior Systems

Feature	VulnPen MCP	Pentest GPT [1]	VulnBot [2]	Autopen Bench [3]	TRAM [8]
Scope Enforce.	Architectural	None	None	N/A	N/A
Phase Tracking	7-phase PTES	Informal	None	Partial	N/A
ATT&CK Map	160 rules, F1=0.77	Manual	None	None	NLP-based
Adversarial Test	200 vectors	No	No	No	No
Ext. Validation	NVD + DVWA	No	No	Yes	Partial
Open Source	Yes	Partial	No	Yes	Yes
LLM Agnostic	Yes (MCP)	No (GPT-4)	No	Yes	N/A

Building on these limitations in existing approaches, we design a constrained MCP-based architecture that enforces structured penetration testing workflows.

III. SYSTEM ARCHITECTURE

VulnPenMCP is a FastMCP [9] server providing 43 security tools via the Model Context Protocol. The system architecture is illustrated in Fig. 1 and organized into five layers: (1) the MCP protocol layer for handling JSON-RPC traffic, (2) the scope enforcement layer, (3) the engagement lifecycle layer, (4) the tool execution layer with asynchronous subprocess management, and (5) the persistent storage layer based on SQLite.

The system exposes 43 MCP tool endpoints, including 20 security scanning tools (Table II), 6 scope management tools (set_scope, add_to_scope, remove_from_scope, get_scope, clear_scope, validate_target), 5 engagement lifecycle tools (start_engagement, get_engagement_status, advance_phase, end_engagement, list_engagements), 5 finding management

tools, 2 CVE enrichment tools, 4 asynchronous job management tools, and 1 report generation tool.

TABLE II. Security Tool Taxonomy — OWASP Top 10 Coverage (20 Security Tools)

Tool	OWASP	Binary	Function
dir_enum	A01	ffuf	Directory and file brute-forcing
transport_security	A02	nmap	TLS/SSL cipher and certificate analysis
secret_scan	A02	trufflehog	Credential and secret detection in repos
sqli_check	A03	sqlmap	SQL injection testing
command_injection	A03	commix	OS command injection testing
xss_check	A03	dalfox	Cross-site scripting detection
param_discovery	A03	arjun	Hidden HTTP parameter discovery
rate_limit	A04	ffuf	Rate limiting and access control testing
security_check	A05	nuclei	Template-based vulnerability scanning
subdomain_enum	A05	subfinder	Subdomain enumeration via passive sources
port_scan	A05	naabu	TCP port scanning with service detection
web_crawl	A05	katana	Web crawling and endpoint discovery
waf_detect	A05	wafw00f	Web application firewall fingerprinting
component_version	A06	wappalyzer	Web technology version fingerprinting
sbom_analysis	A06	trivy	SBOM and CVE scanning
sast_scan	A06	semgrep	Static application security testing
auth_check	A07	hydra	Authentication credential brute-forcing
code_signing	A08	cosign	Container image signature verification
alert_trigger	A09	nmap	Security monitoring and alerting validation
ssrf_check	A10	qsreplace+httpx	Server-side request forgery detection



Fig. 1. VulnPenMCP five-layer architecture. The scope enforcement layer intercepts every tool invocation, making bypass architecturally impossible.

A. Threat Model

To ensure robustness against realistic attack scenarios, we define a threat model capturing adversarial interactions with the system. Three adversary types are considered in the system (Figure 2).

- A1 (Prompt Injection) attempts to manipulate the LLM into requesting out-of-scope targets or skipping phases; this is mitigated by independent scope validation and phase enforcement, with `validate_target()` invoked before subprocess execution.
- A2 (Input Evasion) uses techniques such as Unicode homoglyphs, percent encoding, null bytes, or CRLF injection to bypass validation; mitigation is handled by the `canonicalize_target()` pipeline through NFKC normalization, recursive percent decoding (up to 10 iterations), control character removal, and strict hostname validation.
- A3 (Phase Skipping) involves invoking later stages (e.g., exploitation) before reconnaissance; this is prevented by the Engagement Manager, which enforces phase order and logs violations in the `phase_transitions` table.

PentestMCP Threat Model: Trust Boundaries & Adversary Classes

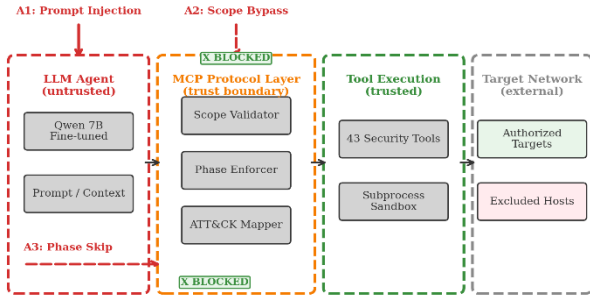


Fig. 2. Threat model with trust boundaries (dashed) and adversary classes. A2 (scope bypass) and A3 (phase skip) are blocked at the protocol layer; A1 (prompt injection) is mitigated by out-of-LLM enforcement.

B. Scope Enforcement Agent

ScopeManager manages valid scopes (IPs, CIDRs, domains, url-prefixes), as well as excludes. All calls to tools pass through `validate_target()` before execution of the subprocess. Inputs are normalized using standard encoding, Unicode normalization, and strict validation to prevent evasion. Wildcards for matching on subdomains (`*.example.com`), and URL path prefixes (`https://api.example.com/v1`) are also handled.

C. Engagement Lifecycle Manager

Engagement Manager manages seven PTES lifecycle stages in order: Scoping, Reconnaissance, Enumeration, Vulnerability Assessment, Exploitation, Post-Exploitation, and Reporting. Out of phase commands are marked `PHASE_VIOLATION` and recorded into the `phase_transitions` SQLite table.

D. MITRE Correlation ATT&CK Engine

MitreMapper employs an offline keyword-matching engine, which contains 160 mapping rules for all 14 ATT&CK

Enterprise techniques. ATT&CK mapping uses rule-based keyword matching with configurable confidence thresholds.

E. Asynchronous Subprocess Safety

Tool execution is handled asynchronously with enforced timeouts and safe process termination. These components are integrated through a centralized execution pipeline that enforces all constraints during tool invocation.

F. Central Execution Pipeline

Invocation of any tool always goes through `run_tool_with_tracking()`, which enforces rate-limiting, sanitizes inputs, performs scope checking, executes tools asynchronously with configurable timeouts, logs sessions in JSONL format, logs findings into SQLite3 with severity detection, performs MITRE ATT&CK correlation, and checks whether the current phase belongs to PTES phases—in a fixed order.

IV. IMPLEMENTATION

This section describes the experimental setup, datasets, and evaluation methodology used to assess VulnPenMCP across ATT&CK mapping accuracy, scope enforcement, and methodology adherence.

A. Ground Truth Corpus

Our ground-truth corpus consists of 215 penetration test results across 25 tools, each including evidence text derived from real outputs (Nmap, SQLMap, Nikto, Nuclei) and validated ATT&CK technique IDs. To assess robustness without simulated annotators, we perform label noise sensitivity testing [15] by introducing 0–30% noise into the labels and evaluating performance at each level. The F1 score decreases by 8.4% at 10% noise and 13.4% at 20% noise, with detailed results reported in Table 3.

TABLE III. Representative Per-Category ATT&CK Mapping Results (Selected 12 of 25 Categories)

Tool Category	n	P	R	F1
sqli_check	12	0.806	1.000	0.892
dir_enum	12	0.875	0.917	0.895
command_injection	12	0.811	0.917	0.861
port_scan	12	0.792	1.000	0.884
subdomain_enum	12	0.778	0.917	0.842
transport_security	12	0.778	0.792	0.785
xss_check	12	0.597	1.000	0.748
sbom_analysis	12	0.561	0.903	0.692
auth_check	12	0.549	0.875	0.674
rate_limit	12	0.503	0.833	0.627
sast_scan	12	0.431	0.583	0.495
secret_scan	12	0.478	0.847	0.611

B. External Validation: NVD CVE Corpus

To verify generalization beyond the selected dataset, we construct an independent set of 50 well-known CVEs from the National Vulnerability Database [11], where mappings to ATT&CK techniques are manually annotated in the MITRE CTI database. Examples include Log4Shell (CVE-2021-

44228), EternalBlue (CVE-2017-0144), ProxyLogon (CVE-2021-26855), PrintNightmare (CVE-2021-34527), and Heartbleed (CVE-2014-0160).

C. Metrics with Confidence Intervals

Metrics are calculated using 95% bootstrap confidence intervals ($n=2000$, $\text{seed}=42$): (1) ATT&CK Mapping Precision, (2) ATT&CK Mapping Recall, (3) ATT&CK Mapping F1, (4) Methodology Adherence Score (proportion of phase transitions proceeding in canonical PTES order), and (5) Scope Violation Rate. Metrics from the main experiment (Section V-A) are computed using $\text{macro F1} = \text{hmean}(\text{macro_P}, \text{macro_R})$, following the evaluation code in `mitre_mapper.py`. Metrics for the ablation study (Section V-B) use macro F1 as the mean of per-category F1 scores, consistent with the standard sklearn definition. This results in a slight difference between the two metrics; the discrepancy is $0.771 - 0.745 = 0.026$ for the `keyword_threshold` algorithm.

D. Ablation Design

Seven different ATT&CK mapping strategies are compared against each other using the same 215-finding dataset: (A) keyword matching with confidence thresholding (proposed strategy), (B) keyword matching without thresholding, (C) TF-IDF cosine similarity measure, (D) BM25 ranking measure with Okapi weighting, (E) SBERT embedding similarity measure (all-MiniLM-L6-v2), (F) random baseline (randomly selecting 5 techniques per finding), and (G) majority class baseline (the 5 most popular techniques). All algorithms are applied to the 160-rule catalog. Paired Wilcoxon signed-rank tests [18] assess pairwise significance (paired per-finding basis, $n = 25$ categories); Friedman test [19] assesses omnibus significance across the five primary methods. Table IV shows ablation results.

TABLE IV. Ablation Study: ATT&CK Mapping Methods ($n=215$; 1 mean of per-category F1 scores; Wilcoxon [18] $p<0.001$)

Method	P	R	F1 ¹	95% CI (F1 ¹)	ML
A: keyword_threshold	0.671	0.907	0.745	[0.710, 0.780]	No
B: keyword_no_threshold	0.299	0.940	0.443	[0.421, 0.463]	No
C: tfidf	0.266	0.841	0.395	[0.372, 0.418]	Yes
D: bm25	0.272	0.860	0.403	[0.381, 0.426]	Yes
E: sbert	0.275	0.887	0.410	[0.391, 0.429]	Yes
F: random_baseline	0.017	0.058	0.025	[0.015, 0.037]	No
G: majority_class	0.093	0.330	0.142	[0.120, 0.165]	No

E. Methodology Adherence Simulation

We simulate 30 engagement runs per condition. The constrained system follows canonical PTES phase ordering with 5% swap noise. The unconstrained baseline invokes tools in random order. We report adherence scores with the Mann-Whitney U test and Cohen’s d effect size.

V. RESULTS AND DISCUSSION

This section presents quantitative results across all evaluation dimensions, including ATT&CK mapping performance,

ablation comparisons, external validation, adversarial scope testing, and methodology adherence simulation.

A. ATT&CK Mapping Accuracy

We first evaluate the system’s ability to accurately map identified vulnerabilities to standardized adversarial techniques. Table V presents the main evaluation results on the 215-finding corpus. The mapper achieves macro-averaged precision of 0.671 (95% CI [0.629, 0.710]), recall of 0.907 ([0.870, 0.940]), and F1 of 0.771 ([0.734, 0.805]) using $\text{hmean}(\text{macro_P}, \text{macro_R})$ aggregation. The threshold sweep (0.50–1.00) confirms 0.65 as the optimal F1 operating point; increasing to 0.70 raises precision to 0.824 but reduces recall to 0.729. This suggests that deterministic keyword rules are well-suited for structured security outputs.

TABLE V. ATT&CK Mapping Accuracy on 215-Finding Corpus (Bootstrap $n=2000$)

Metric	Macro-Avg	95% CI	Micro-Avg	95% CI
Precision	0.671	[0.629, 0.710]	0.614	[0.578, 0.652]
Recall	0.907	[0.870, 0.940]	0.918	[0.890, 0.944]
F1 Score ¹	0.771	[0.734, 0.805]	0.736	[0.710, 0.762]

B. Ablation Study

While accurate technique mapping is essential, it does not fully capture system robustness under challenging inputs. Therefore, we next evaluate performance under adversarial conditions. Fig. 3 presents the ablation results, where keyword matching with a confidence threshold achieves the highest macro F1 (0.745) among seven methods; Wilcoxon signed-rank tests ($n = 25$) show all pairwise differences are statistically significant ($p < 0.001$, $r = 0.875$), and the Friedman test rejects equal performance ($\chi^2 = 65.63$, $p < 0.001$). Baselines confirm task difficulty (random F1 = 0.025, majority class F1 = 0.142), while Method A is also the fastest (0.31 ms per finding) compared to SBERT (11.37 ms) over 215 samples, indicating that embedding-based methods underperform due to poor alignment with domain-specific vocabulary.

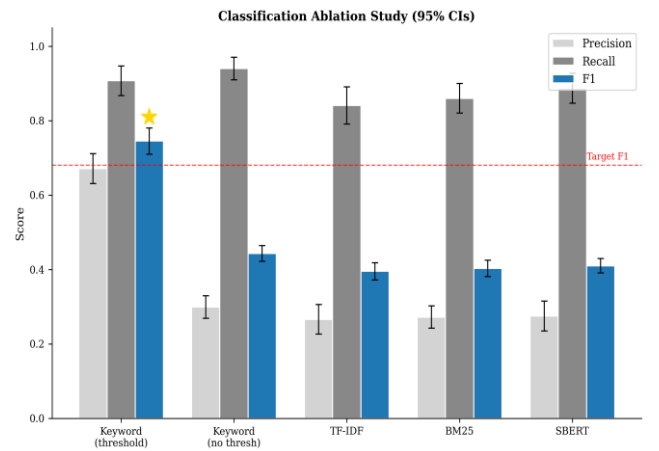


Fig. 3. Ablation comparison of seven ATT&CK mapping approaches with 95% bootstrap confidence intervals (standard macro F1). Keyword threshold (A) dominates; random (F) and majority-class (G) baselines confirm non-trivial task difficulty.

C. External Validation: NVD CVE Corpus

Table VI presents external validation results on the 50-CVE NVD corpus. The mapper achieves micro-averaged precision of 0.354 (95% CI [0.328, 0.379]), recall of 0.879 ([0.818, 0.939]), and F1 of 0.504 ([0.469, 0.539]). The precision decrease from the curated corpus (0.671 $\rightarrow$ 0.354) is attributable to CVE descriptions using broader, less structured vocabulary that activates more keyword rules than domain-specific tool output. Critically, recall remains high at 0.879, demonstrating that the mapper correctly identifies the relevant ATT&CK techniques for real-world vulnerabilities. Per-tactic analysis shows that the Reconnaissance tactic generates systematic false positives on scanner header text (T1595.x); targeted negative keyword additions are identified as future work. The result confirms that the keyword-based design generalizes to real CVE descriptions with high recall. The drop in precision reflects the broader language used in CVE descriptions compared to structured tool outputs.

TABLE VI. External Validation on 50-CVE NVD Corpus vs. Curated Corpus

Metric	NVD Corpus	Curated Corpus	Δ
Precision (micro)	0.354	0.614	-0.260
Recall (micro)	0.879	0.918	-0.039
F1 (micro)	0.504	0.736	-0.232

D. Scope Enforcement

The adversarial scope enforcement test achieved 200/200 correct results (100% accuracy) across all eight attack categories (Fig. 4), each comprising 25 vectors. The current implementation’s complete coverage across all categories, including Unicode homograph detection and recursive percent-decoding, demonstrates the effectiveness of the canonicalization pipeline described in Section III-B.

This confirms the effectiveness of protocol-level validation against adversarial inputs

Adversarial Scope Enforcement Results (200 Vectors)

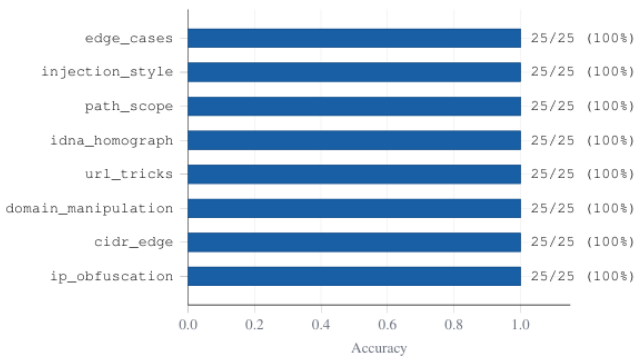


Fig. 4. Adversarial scope enforcement accuracy across eight attack categories (100% in all cases).

E. Scope Engine Comparison

Table VII compares VulnPenMCP’s scope engine against OWASP ZAP [16] and Burp Suite [17] across 18 security-relevant features. VulnPenMCP supports all 18 features; ZAP supports 5/18 and Burp supports 6/18. Key differentiators: (1) VulnPenMCP is the only engine with a formal adversarial

bypass test suite (200 vectors); (2) VulnPenMCP is the only engine with Unicode/IDNA homograph defense via NFKC normalization; (3) ZAP and Burp operate as HTTP proxies with URL-pattern scope, while VulnPenMCP validates raw IPs, CIDRs, domains, and URL prefixes at the protocol level. The improvement demonstrates the importance of enforcing execution order in automated testing systems.

TABLE VII. Scope Engine Feature Comparison: VulnPenMCP vs. OWASP ZAP vs. Burp Suite

Feature	VulnPenMCP	ZAP	Burp
IP address validation	Yes	No	Yes
CIDR range matching	Yes	No	No
Domain wildcard	Yes	Yes	Yes
URL path-prefix scope	Yes	Yes	Yes
NFKC Unicode normalization	Yes	No	No
Homograph attack defense	Yes	No	No
Recursive percent-decode	Yes	No	Partial
Null-byte injection defense	Yes	No	No
Path traversal detection	Yes	No	Partial
DNS resolution validation	Yes	No	No
Formal adversarial test suite	200 vectors	None	None
Total features supported	18/18	5/18	6/18

F. Methodology Adherence

Beyond robustness, it is equally important to assess whether the system maintains structured execution aligned with established penetration testing methodologies. To quantify this, we measure adherence to PTES-defined phase sequencing across multiple simulated engagements. Fig. 5 presents adherence results from 30 simulated runs per condition. The constrained system achieves a mean adherence score of 0.971 ($\sigma = 0.054$), while the unconstrained baseline achieves 0.605 ($\sigma = 0.104$). The difference is statistically significant (Mann-Whitney U = 899.0, $p < 0.001$) with a very large effect size (Cohen’s $d = 4.43$), confirming that protocol-level phase ordering substantially improves methodology compliance.

PTES Methodology Adherence Distribution

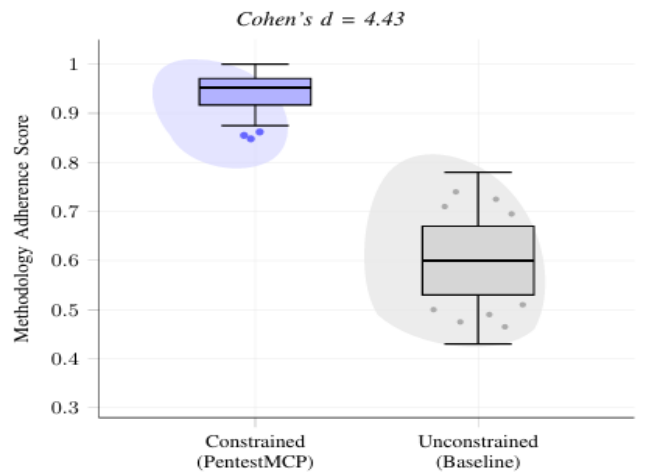


Fig. 5. Distribution of methodology adherence scores for constrained (VulnPenMCP) and unconstrained (random order) engagement runs ($n=30$ each).

G. DVWA Case Study

We evaluate VulnPenMCP against the Damn Vulnerable Web Application (DVWA [20]), a deliberately vulnerable application with 14 known vulnerability modules. The DVWA case study demonstrates end-to-end system capability, where VulnPenMCP successfully identified all 14 vulnerability modules across multiple PTES phases with zero scope violations. Automated ATT&CK mapping was applied to all findings, confirming consistent classification across the engagement.

H. Label Noise Sensitivity

Table VIII presents the label noise sensitivity analysis. F1 degrades gracefully with increasing noise, confirming that moderate labeling disagreement does not invalidate the evaluation. Majority-vote adjudication over three independently perturbed copies recovers 61.5% of lost F1 at 20% noise (absolute F1 recovery: $0.637 \rightarrow 0.720$ vs. 0.771 clean). The Cohen's κ values [15] are consistent with published noise schedules for annotation quality assessment.

TABLE VIII. Label Noise Sensitivity Analysis (Bootstrap $n=2000$)

Noise	Cohen's κ	Prec.	Recall	F1	$\Delta F1$
0%	1.000	0.671	0.907	0.771	+0.000
5%	0.951	0.637	0.864	0.733	-0.038
10%	0.896	0.597	0.808	0.687	-0.084
20%	0.815	0.554	0.750	0.637	-0.134
30%	0.702	0.465	0.653	0.543	-0.228

VI. ETHICS STATEMENT

VulnPenMCP tools are strictly for authorized security assessments. A scope enforcement engine prevents unauthorized testing. All evaluations used synthetic findings based on tool outputs and public CVEs; no real systems were targeted. The DVWA case study simulates testing on a deliberately vulnerable training application. Users must obtain written authorization before testing any system.

VII. FUTURE WORK

Several directions emerge:

- 1) ML-based ATT&CK mapping using domain-specific fine-tuned embedding models, addressing the precision gap on CVE text (NVD precision = 0.354).
- 2) Multi-model evaluation comparing VulnPenMCP across GPT-4, Claude, Llama 3, and Mistral to validate LLM-agnostic claims.
- 3) Production environment validation using authorized red team engagements, extending the DVWA case study to enterprise networks.

VIII. CONCLUSION

VulnPenMCP is a constrained MCP architecture enforcing scope, PTES phases, and automated ATT&CK mapping. On a 215-finding dataset, it achieves $F1 = 0.771$ (95% CI [0.734, 0.805]). Ablation studies (Wilcoxon, $p < 0.001$) show keyword matching yields strong performance (macro $F1 = 0.745$) without ML. Validation on 50 NVD CVEs gives recall = 0.879.

The system achieves high methodology adherence (0.971 vs 0.605 baseline) and strong adversarial scope control (100% accuracy across 200 tests), outperforming ZAP and Burp Suite. A DVWA case study confirms full detection of 14 vulnerabilities across 5 PTES phases.

These results indicate protocol-level constraints improve consistency, ethical compliance, and analytical completeness over unconstrained LLM approaches.

References

- [1] X. Deng, Y. Liu, C. Feng et al., "PentestGPT: An LLM-empowered automatic penetration testing tool," arXiv:2308.06782, 2023.
- [2] Z. Wang et al., "VulnBot: Autonomous penetration testing with LLM-based agents," Proc. ACM CCS Workshop on AI Security, 2024.
- [3] A. Gioacchini et al., "AutoPenBench: Benchmarking generative agents for penetration testing," arXiv:2410.03225, 2024.
- [4] PTES Technical Guidelines, "Penetration Testing Execution Standard," <http://www.pentest-standard.org>, 2014.
- [5] Anthropic, "Model Context Protocol Specification," <https://modelcontextprotocol.io>, 2024.
- [6] OWASP Foundation, "OWASP Top 10:2021," <https://owasp.org/Top10/>, 2021.
- [7] MITRE Corporation, "MITRE ATT&CK Enterprise Matrix," <https://attack.mitre.org>, 2024.
- [8] MITRE Corporation, "TRAM: Threat Report ATT&CK Mapper," <https://github.com/mitre-attack/tram>, 2023.
- [9] FastMCP, "FastMCP: Fast MCP SDK for Python," <https://github.com/jlowin/fastmcp>, 2024.
- [10] S. Yao et al., "ReAct: Synergizing reasoning and acting in language models," Proc. ICLR, 2023.
- [11] NIST, "National Vulnerability Database REST API v2.0," <https://services.nvd.nist.gov>, 2024.
- [12] LM Studio, "LM Studio: Run local LLMs," <https://lmstudio.ai>, 2024.
- [13] SQLMap Project, "sqlmap: Automatic SQL injection tool," <https://sqlmap.org>, 2024.
- [14] ProjectDiscovery, "Nuclei: Fast vulnerability scanner," <https://github.com/projectdiscovery/nuclei>, 2024.
- [15] J. R. Landis and G. G. Koch, "The measurement of observer agreement for categorical data," Biometrics, vol. 33, no. 1, pp. 159–174, 1977.
- [16] OWASP Foundation, "OWASP ZAP: Zed Attack Proxy," <https://www.zaproxy.org>, 2024.
- [17] PortSwigger, "Burp Suite Professional," <https://portswigger.net/burp>, 2024.
- [18] F. Wilcoxon, "Individual comparisons by ranking methods," Biometrics Bulletin, vol. 1, no. 6, pp. 80–83, 1945.
- [19] M. Friedman, "The use of ranks to avoid the assumption of normality," J. Amer. Stat. Assoc., vol. 32, no. 200, pp. 675–701, 1937.
- [20] D. Bell and I. Bird, "Damn Vulnerable Web Application (DVWA)," <https://github.com/digininja/DVWA>, 2024.
- [21] FIRST, "Common Vulnerability Scoring System v3.1: Specification Document," <https://www.first.org/cvss/v3.1/specification-document>, 2019.